

الوحدة 20: SIEM و SOAR والمراقبة الأمنية

(SIEM (Security Information and Event Management

يجمع SIEM السجلات من مصادر متعددة (خوادم، جدران حماية، أنظمة كشف الاختراق) ويربطها لتحليل الأحداث الأمنية في الوقت الفعلي. المكونات الرئيسية: جمع السجلات (Log Collection)، تطبيع البيانات (Normalization)، الربط الزمني (Correlation)، التنبيهات (Alerts)، التقارير (Reports).

أمثلة: Splunk, ELK Stack, IBM QRadar, ArcSight.

Syslog: بروتوكول قياسي لجمع السجلات. يستخدم المنفذ UDP 514 (أو TCP 6514 للتشفير).

مثال: استعراض سجلات Windows باستخدام wevtutil

```
wevtutil qe Security /c:10 /rd:true /f:text
wevtutil gl Security
```

`wevtutil qe Security` - أداة استعلام سجلات الأحداث (Security Query Events). هو اسم سجل الأمان.
`/c:10` - عدد الأحداث المراد عرضها (Count). يحد من النتائج لأحدث 10 أحداث.
`/rd:true` - ترتيب تنازلي (Newest first). يعرض أحدث الأحداث أولاً للتحليل الفوري.
`/f:text` - تنسيق النص (بدلاً من XML). يجعل القراءة أسهل للمبتدئين.
`wevtutil gl Security` - عرض معلومات السجل (Get-Log): الحجم، عدد الأحداث، تاريخ الإنشاء.

مثال: استعلام الأحداث باستخدام PowerShell (Get-WinEvent)

```
Get-WinEvent -LogName Security | Where-Object {$_.Id -eq 4625} | Select-Object TimeCreated
```

`Get-WinEvent -LogName Security` - جلب جميع الأحداث من سجل الأمان. أقوى وأسرع من `Get-EventLog`.
`{Where-Object {$_.Id -eq 4625}}` - تصفية الأحداث: 4625 هو معرف حدث فشل تسجيل الدخول. مفيد لكشف هجمات القوة العمياء.
`Select-Object TimeCreated,Message -First 5` - عرض الحقول المحددة (الوقت والرسالة) لأول 5 نتائج فقط.

(SOAR (Security Orchestration, Automation and Response

منصة تنسق أدوات الأمن وتوتمت الاستجابات للحوادث. تتكامل مع SIEM و Ticketing Systems.

Playbook: سير عمل يدوي (إجراءات خطوة بخطوة للاستجابة للحادثة). مثل: دليل استجابة لهجوم Ransomware.

Runbook: نسخة آلية من Playbook. ينفذ الإجراءات تلقائياً عند اكتشاف تهديد. مثال: عزل جهاز مصاب تلقائياً عبر API.

فوائد SOAR: سرعة الاستجابة، تقليل الأخطاء البشرية، توثيق كامل للإجراءات.

المراقبة الأمنية وتحليل المرور

NetFlow/sFlow: إحصائيات تدفق الشبكة لتحليل أنماط المرور وتحديد الشذوذ.

Packet Capture: التقاط الحزم كاملة للتحليل العميق.

مثال: التقاط وتحليل الحزم باستخدام tcpdump و Wireshark

```
tcpdump -i eth0 -n host 10.0.0.5 and port 80 -c 100 -w capture.pcap
```

`tcpdump -i eth0` - أداة التقاط الحزم. `-i eth0` يحدد واجهة الشبكة.

`-n` - لا تحل أسماء DNS (يبقى الأرقام). يمنع تأخير الاستعلام عن DNS.

`host 10.0.0.5 and port 80` - التقاط الحزم من/إلى العنوان 10.0.0.5 على المنفذ 80 (HTTP).

`-c 100` - التقاط 100 حزمة فقط ثم التوقف. `-w capture.pcap` - حفظ النتيجة لتحليلها لاحقاً.

فلاتر Wireshark الشائعة:

```
ip.addr == 192.168.1.1
tcp.port == 443
http.request.method == "GET"
tls.handshake.type == 1
```

`ip.addr == 192.168.1.1` - عرض حزم IP المصدر أو الوجهة من/إلى عنوان معين.

`tcp.port == 443` - عرض حزم HTTPS فقط. مفيد لمراقبة المرور المشفر.

`"http.request.method == \"GET\"` - عرض طلبات HTTP GET فقط. يكشف روابط التحميل وأنماط التصفح.

`tls.handshake.type == 1` - عرض حزم Client Hello (بداية اتصال TLS). يكشف أي تطبيقات تستخدم TLS.

(Quick Quiz (MCQ

1. What does SIEM stand for ?

- a) System Integration and Event Management
- b) Security Information and Event Management
- c) Security Infrastructure and Emergency Monitoring

d) System Integrity and Error Management

Answer: b

?What is the primary function of a SIEM system .2

- a) Encrypt network traffic
- b) Centralized log aggregation, correlation, and analysis
- c) Block malware in real-time
- d) Manage firewall rules

Answer: b

?In the context of SOAR, what are playbooks .3

- a) Hardware configuration guides
- b) Step-by-step automated incident response procedures
- c) Network topology diagrams
- d) Software license agreements

Answer: b

?What is the key difference between a playbook and a runbook .4

- a) Playbooks are for hardware, runbooks for software
- b) Playbooks describe strategic response workflows, runbooks contain specific operational steps
- c) They are exactly the same thing
- d) Runbooks are only used in cloud environments

Answer: b

?What does EDR (Endpoint Detection and Response) primarily monitor .5

- a) Network bandwidth usage
- b) Individual endpoints for suspicious activity and threats
- c) Email server logs
- d) DNS query patterns

Answer: b